

Registre des traitements — Start Academy (art. 30 RGPD)

Champ	Valeur
Version	1.0
Date de rédaction	2026-07-06
Responsable de traitement	Start Academy — Organisme de formation certifié Qualiopi (siège : Vence)
Contact	laurent@start-academy.fr
Rédaction	Générée par assistance IA (Claude), sous contrôle du responsable de traitement
Statut	⚠ EN ATTENTE DE VALIDATION par le responsable de traitement (gate D-13 — aucune circulation de PII de production tant que ce registre n'est pas validé)

Ce registre couvre les traitements de données à caractère personnel opérés via l'application interne **QualiOF** (CRM/back-office de Start Academy, non commercialisé à des tiers) déployée sur infrastructure cloud (voir § Localisation des données). Il est versionné dans le dépôt de code (`docs/rgpd/`) et exportable en PDF pour présentation à un auditeur Qualiopi ou à la CNIL.

Traitement 1 — Gestion des apprenants et des sessions (CRM 360°)

Rubrique	Contenu
Finalité	Gestion du cycle de vie des formations : dossiers apprenants, sessions, émargements, suivi pédagogique et conformité Qualiopi.
Base légale	Exécution du contrat de formation (art. 6.1.b RGPD) ; obligations légales de l'OF (art. 6.1.c) pour les pièces exigées par le Code du travail / Qualiopi.
Catégories de données	Identité (nom, prénom, nom de naissance, date de naissance, civilité), coordonnées (email, téléphone, adresse personnelle), parcours (niveau d'études, diplômes, expérience et statut professionnels), casquettes juridiques EI/Enseigne (liens <code>Person</code> ↔ <code>Organization</code> via <code>LegalLink</code>).
Catégories de personnes	Apprenants, formateurs, contacts d'organisations, prospects.
Destinataires / sous-traitants	Hébergement base : <code>dpa/supabase.md</code> · Hébergement applicatif : <code>dpa/vercel.md</code> .
Durée de conservation	Proposée : durée de la relation contractuelle + durée du cycle de certification Qualiopi (preuves d'audit), puis archivage limité aux obligations légales. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT (durée exacte à confirmer).
Mesures techniques	Multi-tenant <code>tenantId</code> sur toutes les tables métier, RBAC 6 rôles (ADMIN/MANAGER/FORMATEUR/COMMERCIAL/COMPTABLE/LECTEUR), sessions Lucia, données sensibles isolées dans la table <code>SensitiveData</code> (1:1 <code>Person</code>).

Traitement 2 — Pré-inscriptions self-service + OCR IA

Rubrique	Contenu
Finalité	Collecte des informations et pièces d'inscription directement auprès du candidat (formulaire public tokenisé), extraction automatique par OCR IA (CNI/RIB/attestation CFP) pour éviter la ressaisie.
Base légale	Mesures précontractuelles à la demande de la personne (art. 6.1.b) ; consentement horodaté sur le formulaire (<code>rgpdAcceptedAt</code>).
Catégories de données	Identité et coordonnées saisies + documents sensibles par nature documentaire : pièce d'identité (CNI), RIB, attestation CFP — uploadés en direct-to-storage vers un bucket privé , accessibles uniquement via signed URLs à TTL de quelques minutes . Données extraites structurées (<code>extractedData</code>).
Catégories de personnes	Candidats à l'inscription (futurs apprenants).
Destinataires / sous-traitants	Storage des pièces : dpa/supabase.md · OCR vision : dpa/openrouter.md (modèles Anthropic via OpenRouter : dpa/anthropic.md) · Runtime formulaire public : dpa/vercel.md .
Durée de conservation	Proposée : pièces d'identité/RIB conservées le temps de la constitution et de la justification du dossier de financement, puis suppression ; lien public à expiration (<code>expiresAt</code>). ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT (notamment la durée de rétention des scans CNI/RIB après conversion en apprenant).
Mesures techniques	Bucket Storage privé + signed URL TTL minutes, upload direct-to-storage (les pièces ne transitent pas par le serveur applicatif), token unique à expiration, table <code>SensitiveData</code> séparée pour la pièce d'identité après conversion, rate-limiting WAF sur <code>/preinscription</code> (30 req/60 s/IP).

Traitement 3 — Génération des documents Qualiopi (pack closure IA)

Rubrique	Contenu
Finalité	Génération assistée par IA des documents de fin de formation (attestations, certificats, QCM, grilles, déroulés...) exigés par le référentiel Qualiopi.
Base légale	Exécution du contrat de formation et obligations de l'OF certifié (art. 6.1.b et 6.1.c).
Catégories de données	Prompts transmis au fournisseur IA contenant : noms des stagiaires, contexte de session (produit, dates, formateur), éléments pédagogiques. Pas de CNI/RIB dans ce flux (l'OCR des pièces relève du Traitement 2).
Catégories de personnes	Apprenants, formateurs.
Destinataires / sous-traitants	IA : dpa/openrouter.md et, en sous-sous-traitance, dpa/anthropic.md · Rendu/stockage des PDF : dpa/railway.md (worker + moteurs PDF) et dpa/supabase.md (Storage).
Durée de conservation	Proposée : documents générés conservés avec le dossier de formation (durée du Traitement 1). Côté fournisseur IA : politique par défaut de non-rétention des prompts chez OpenRouter (voir fiche). ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.
Mesures techniques	Worker isolé (Railway, région EU), authentification Bearer (<code>DOC_ENGINE_TOKEN</code>) sur les moteurs PDF exposés, audit des logs PII réalisé (plan 22-02) : les logs applicatifs référencent des IDs, pas de PII brut.

Traitement 4 — Facturation et relances (trésorerie OPCO/AGEFICE)

Rubrique	Contenu
Finalité	Émission des factures et avoirs, suivi des encaissements (CA prévu/signé/encaissé, DSO), relances de paiement, suivi des budgets AGEFICE par apprenant et par année.
Base légale	Exécution du contrat (art. 6.1.b) : obligations comptables et fiscales (art. 6.1.c).

Rubrique	Contenu
Catégories de données	Identité et coordonnées des payeurs (règle métier : l'auto-entrepreneur est son propre payeur — une relance facture peut donc toucher directement un apprenant), montants, dates d'échéance, emails de relance.
Catégories de personnes	Payeurs : organisations (enseignes, financeurs OPCO/AGEFICE) et personnes physiques (apprenants auto-entrepreneurs).
Destinataires / sous-traitants	Base et PDF factures : dpa/supabase.md · Envoi des relances : dpa/ovh-smtp.md · Cron de relance : dpa/railway.md .
Durée de conservation	Proposée : pièces comptables 10 ans (obligation légale du Code de commerce — durée usuelle, non négociable). Données de relance : durée du dossier. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.
Mesures techniques	<code>MAIL_DRY_RUN</code> actif tant que la bascule production n'est pas validée (aucun email réel), montants stockés en centimes, RBAC (rôle COMPTABLE), scoping <code>tenantId</code> .

Traitement 5 — Emails transactionnels (convocations, notifications)

Rubrique	Contenu
Finalité	Envoi des convocations, notifications de documents et suivis liés aux formations.
Base légale	Exécution du contrat de formation (art. 6.1.b).
Catégories de données	Adresses email des apprenants et payeurs, contenus des emails (noms, sessions, pièces jointes documentaires).
Catégories de personnes	Apprenants, payeurs, formateurs.
Destinataires / sous-traitants	Transport SMTP : dpa/ovh-smtp.md .
Durée de conservation	Proposée : traces d'envoi (<code>EmailMessage</code>) conservées avec le dossier de formation. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.
Mesures techniques	Aucun envoi de masse vers les apprenants sans action explicite (exigence du responsable de traitement : <code>notifyLearners</code> défaut <code>false</code> , boutons manuels, opt-in par case à cocher) ; crons de relance préinscriptions/OPCO volontairement débranchés ; <code>MAIL_DRY_RUN</code> en staging ; connexion SMTP chiffrée (SSL :465).

Traitement 6 — Synchronisation Google Calendar (rappels formations)

Rubrique	Contenu
Finalité	Création automatique d'événements de rappel de sessions dans un agenda dédié (« Rappel Formations »), avec liens vers les documents/programmes (Google Drive).
Base légale	Intérêt légitime de l'OF (organisation interne des formations, art. 6.1.f). ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT (qualification de la base légale).
Catégories de données	Noms des sessions et des formateurs dans les événements ; emails des apprenants en tant qu'invités (attendees) ; programmes de formation sur Drive.
Catégories de personnes	Apprenants, formateurs.

Rubrique	Contenu
Destinataires / sous-traitants	dpa/google.md — ⚠ type de compte (gratuit vs Workspace) à confirmer, voir fiche.
Durée de conservation	Proposée : événements conservés dans l'agenda tant que la session figure au dossier de formation. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.
Mesures techniques	<code>sendUpdates= ' none '</code> par défaut (les invités ne reçoivent pas de notification Google), OAuth à scope minimal (calendar uniquement), garde staging (synchronisation désactivée hors production).

Traitement 7 — Comptes utilisateurs internes (RBAC)

Rubrique	Contenu
Finalité	Authentification et gestion des droits des utilisateurs internes de Start Academy sur QualiOF.
Base légale	Intérêt légitime (sécurité et administration du SI interne, art. 6.1.f) ; exécution du contrat de travail pour les salariés.
Catégories de données	Email professionnel, nom, mot de passe (haché argon2 — jamais stocké en clair), rôle, sessions d'authentification, journal d'audit (<code>AuditLog</code>).
Catégories de personnes	Utilisateurs internes (dirigeant, équipe administrative, formateurs, commerciaux, comptable).
Destinataires / sous-traitants	dpa/supabase.md , dpa/vercel.md .
Durée de conservation	Proposée : durée du compte + journal d'audit conservé pour traçabilité. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.
Mesures techniques	Hachage argon2, sessions Lucia (cookies httpOnly, <code>secure</code> en production, <code>sameSite=lax</code>), RBAC 6 rôles, invalidation de session en base au logout.

Traitement 8 — Veille réglementaire (RSS + IA)

Rubrique	Contenu
Finalité	Veille automatisée sur les sources réglementaires de la formation professionnelle (flux RSS résumés par IA).
Base légale	Intérêt légitime (obligation de veille Qualiopi, indicateur 23-25).
Catégories de données	Aucune PII apprenant — contenus publics des flux RSS uniquement.
Catégories de personnes	N/A (pas de personne concernée au sens PII apprenant ; auteurs d'articles publics le cas échéant).
Destinataires / sous-traitants	IA de résumé : dpa/openrouter.md · Exécution : dpa/railway.md .
Durée de conservation	Articles et résumés conservés à des fins de preuve Qualiopi (indicateur veille).
Mesures techniques	Flux isolé, aucun croisement avec les données apprenants.

Localisation des données

Source de vérité : `.planning/phases/17-fondations-cloud-r-gion-eu-env/17-REGIONS.md` (verrouillage régions EU, Phase 17, amendé Phase 21).

Plateforme	Rôle	Région	Pays
Supabase (projet <code>gntlqyscahbgjrmsbzil</code>)	Base Postgres + Storage (pièces CNI/RIB/PDF)	<code>eu-west-1</code> (définitive — région immuable, dérogation actée)	Irlande (UE)
Vercel	Application + fonctions serverless	<code>cdg1</code>	France (Paris)
Railway	Worker de génération + moteurs PDF	<code>europa-west4</code>	Pays-Bas (UE)
OVH (SMTP <code>ssl0.ovh.net:465</code>)	Envoi d'emails	Infrastructure OVH	France (UE)

Note Vercel : les fonctions s'exécutent en `cdg1` (Paris) mais le réseau edge de Vercel est mondial — les réponses HTTP transitent par le point de présence le plus proche du visiteur (voir [dpa/vercel.md](#)).

Transferts hors UE

Flux	Destinataire	Pays	Garanties
Prompts IA (closure, OCR vision)	OpenRouter, Inc.	États-Unis	Politique par défaut de non-rétention des prompts (métadonnées seules) ; réglages compte ZDR/logging à vérifier et capturer. ⚠ Pas de DPA mutuellement signé en tier self-serve (réservé entreprise) — limite documentée honnêtement dans dpa/openrouter.md . ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.
Inférence des modèles Claude	Anthropic, PBC (via OpenRouter — sous-sous-traitant)	États-Unis	Pas de relation contractuelle directe : la chaîne contractuelle passe par OpenRouter. Voir dpa/anthropic.md .
Google Calendar / Drive	Google	Selon le type de compte (⚠ à confirmer — voir dpa/google.md)	Compte gratuit = conditions grand public sans DPA processeur (point d'attention majeur) ; Workspace = DPA processeur (Cloud Data Processing Addendum). ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT.

Registre des sous-traitants (art. 28)

#	Sous-traitant	Rôle	Données transmises	Fiche
1	OpenRouter	Passerelle IA (closure + OCR vision)	Prompts : noms stagiaires, contexte sessions, images CNI/RIB (OCR)	dpa/openrouter.md
2	Anthropic	Fournisseur des modèles Claude (sous-sous-traitant via OpenRouter)	Idem OpenRouter (inférence)	dpa/anthropic.md
3	Supabase	Base Postgres + Storage	TOUTE la base (PII apprenants, SensitiveData) + pièces (CNI/RIB/PDF)	dpa/supabase.md
4	Vercel	Hébergement application	Runtime app : cookies de session, formulaire public de préinscription	dpa/vercel.md

#	Sous-traitant	Rôle	Données transmises	Fiche
5	Railway	Worker + moteurs PDF	Génération de documents, logs (audités D-17, plan 22-02)	dpa/railway.md
6	Google	Calendar (events sessions) + Drive (programmes)	Noms sessions/formateurs, emails apprenants en attentes	dpa/google.md
7	OVH	SMTP transactionnel	Emails apprenants/payeurs (convocations, relances factures)	dpa/ovh-smtp.md

Mesures techniques et organisationnelles (synthèse)

- **Isolement des données sensibles** : table `SensitiveData` séparée (n° SS, pièce d'identité), relation 1:1 avec `Person`, suppression en cascade.
- **Storage privé** : bucket non public, accès exclusivement par **signed URL à TTL de quelques minutes** ; upload direct-to-storage (les pièces ne transitent pas par les serveurs applicatifs).
- **Contrôle d'accès** : RBAC 6 rôles (ADMIN/MANAGER/FORMATEUR/COMMERCIAL/COMPTABLE/LECTEUR), authentification Lucia + argon2, multi-tenant `tenantId` systématique sur les requêtes.
- **Régions EU verrouillées** par écrit (Phase 17) avec checklist anti-défaut-US ; Supabase `eu-west-1`, Vercel `cdg1`, Railway `europa-west4`.
- **Sauvegardes** : backups Supabase quotidiens, rétention 7 jours, stockés dans la même région que le projet (eu-west-1, UE).
- **Emails** : dry-run par défaut hors production, aucun envoi de masse apprenants sans action explicite (opt-in), SMTP chiffré :465.
- **Logs** : audit des `console.*` réalisé (plan 22-02) — les logs applicatifs référencent des identifiants techniques, jamais nom/CNI/RIB en clair.
- **Secrets** : jamais en clair dans le dépôt ; variables d'environnement chiffrées (sensitive) sur Vercel/Railway.

Limites connues (assumées, non masquées)

1. **Backups non off-site** : les sauvegardes Supabase quotidiennes (7 jours) résident dans la **même région que le projet** (eu-west-1). Un export `pg_dump` périodique vers un stockage hors vendor est au backlog (décision D-12). ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT (acceptation du risque).
2. **OpenRouter sans DPA signé** en tier self-serve (voir Transferts hors UE et [dpa/openrouter.md](#)) — mitigations : politique de non-rétention par défaut, réglages ZDR/logging OFF, passage au tier entreprise si exigé. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT (acceptation du risque).
3. **Type de compte Google inconnu** au moment de la rédaction — question posée au responsable de traitement au checkpoint de validation (voir [dpa/google.md](#)).

Validation du responsable de traitement (gate D-13)

- ☐ Les 8 traitements ci-dessus sont exacts et complets.
- ☐ Les durées de conservation proposées sont confirmées ou amendées.
- ☐ La question du type de compte Google (gratuit vs Workspace) est tranchée.
- ☐ Les 2 limites assumées (backups non off-site, OpenRouter self-serve) sont acceptées.

Statut : ⚠ EN ATTENTE DE VALIDATION — la bascule production (plan 22-06) ne démarre pas sans cette validation.
 Start Academy — Registre des traitements — généré le 6 juillet 2026

Fiche DPA — Anthropic

Champ	Valeur
Fournisseur	Anthropic, PBC (États-Unis)
Rôle	Sous-sous-traitant — atteint VIA OpenRouter : pas de relation contractuelle directe Start Academy ↔ Anthropic
Service utilisé	Modèles Claude (Haiku = fast, Sonnet = quality) consommés à travers la passerelle OpenRouter (génération docs closure + OCR vision)
Données transmises	Identiques au flux OpenRouter (voir openrouter.md) : prompts contenant noms stagiaires + contexte sessions, images CNI/RIB pour l'OCR — transmises par OpenRouter à Anthropic pour l'inférence
Localisation	États-Unis (transfert hors UE)
Document DPA public	Anthropic publie ses conditions commerciales et son Data Processing Addendum : https://www.anthropic.com/legal/commercial-terms et https://www.anthropic.com/legal/data-processing-addendum (vérifiées 200 le 2026-07-06). ⚠ Ces documents s'appliquent aux clients directs d'Anthropic — Start Academy n'est PAS partie à ces contrats : la chaîne contractuelle passe par OpenRouter.
Garanties de transfert hors UE	Portées par la chaîne OpenRouter → Anthropic (subprocessor d'OpenRouter). Le choix ZDR côté OpenRouter restreint le routage aux endpoints sans rétention. ⚠ Le détail de l'accord OpenRouter ↔ Anthropic n'est pas public — à signaler comme trou honnête, pas d'invention.
Date de vérification	2026-07-06 (URLs re-vérifiées HTTP 200)

Points ouverts / limites

- ⚠ **Aucun lien contractuel direct** : Start Academy ne peut pas produire de DPA signé avec Anthropic. Le document opposable est la relation avec OpenRouter (elle-même limitée en self-serve — voir openrouter.md).
- La politique du model provider (anthropic.com/legal) est référencée à titre d'information sur les pratiques du fournisseur de modèles, pas comme engagement contractuel envers Start Academy.
- ⚠ **À VALIDER PAR LE RESPONSABLE DE TRAITEMENT** : acceptation de cette chaîne de sous-traitance à deux niveaux (OpenRouter → Anthropic) pour les flux IA.

Fiche DPA — Google (Calendar + Drive)

Champ	Valeur
Fournisseur	Google LLC / Google Ireland Ltd (selon le type de compte)
Rôle	Sous-traitant (art. 28 RGPD) — △ qualification dépendante du type de compte (voir variantes)
Service utilisé	Google Calendar (agenda dédié « Rappel Formations » : events de rappel J-15...J-1 par session) + Google Drive (programmes de formation DOCX, dossier Start Academy/Formations et programmes/)
Données transmises	Calendar : noms des sessions et des formateurs dans les events, emails des apprenants en attente es (avec sendUpdates= ' none ' — pas de notification envoyée par Google) ; Drive : programmes de formation (pas de PII apprenant)
Localisation	Infrastructure mondiale Google — pas de garantie de résidence UE par défaut
Document DPA public	Dépend du type de compte — voir les 2 variantes ci-dessous
Date de vérification	2026-07-06 (URLs re-vérifiées HTTP 200)

[△](#) QUESTION BLOQUANTE — à CONFIRMER par Laurent au checkpoint (Open Question 1)

Le compte Google utilisé pour Calendar/Drive est-il un compte GRATUIT (grand public) ou un compte GOOGLE WORKSPACE (payant) ?

Les deux variantes sont rédigées ci-dessous ; la bonne sera conservée (et l'autre supprimée) après la réponse au checkpoint de validation du registre.

VARIANTE A — Compte Google gratuit (grand public)

- **Cadre contractuel** : conditions d'utilisation grand public + politique de confidentialité <https://policies.google.com/privacy> (vérifiée 200 le 2026-07-06).
- [△](#) **PAS de DPA processeur** : dans les conditions grand public, Google n'agit pas comme sous-traitant au sens de l'art. 28 avec engagements contractuels dédiés — **point d'attention MAJEUR** puisque des données personnelles de tiers (noms sessions/formateurs, **emails d'apprenants en attente**es) sont placées dans les events Calendar.
- **Mitigations en place** : scope OAuth minimal (calendar uniquement), sendUpdates= ' none ' (aucun email envoyé par Google aux apprenants), agenda dédié séparé.
- **Mitigation backlog : migration vers Google Workspace** (variante B) pour obtenir le DPA processeur ; alternativement, retirer les emails apprenants des attentees (events informatifs sans invités).
- [△](#) À VALIDER PAR LE RESPONSABLE DE TRAITEMENT : acceptation temporaire du risque + arbitrage sur la migration Workspace.

VARIANTE B — Compte Google Workspace (payant)

- **Cadre contractuel** : Google Workspace inclut le **Cloud Data Processing Addendum** (DPA processeur) : https://workspace.google.com/terms/dpa_terms.html (vérifiée 200 le 2026-07-06).

- Google agit comme sous-traitant avec engagements art. 28 : clauses contractuelles types pour les transferts hors UE, liste de subprocessors publiée, certifications (ISO 27001 etc.).
 - **Action si cette variante s'applique** : vérifier que le DPA/CCT sont bien acceptés dans la console d'administration Workspace et conserver la preuve.
 - Mitigations techniques identiques (scope minimal, `sendUpdates= 'none'`).
-

Mesures techniques côté QualiOF (communes)

- Refresh token OAuth à **scope calendar SEUL** (pas d'accès Gmail/autres) — porté en variable d'environnement chiffrée Vercel à la bascule (D-07).
- `sendUpdates= 'none'` par défaut : les apprenants invités ne reçoivent aucun email de Google.
- Garde staging : aucune synchronisation Calendar hors production.

Points ouverts / limites

- ⚠ **Type de compte à confirmer** (question bloquante ci-dessus) — la fiche sera figée sur la bonne variante après le checkpoint.
- ⚠ Localisation des données Google non garantie UE (les deux variantes) — transfert encadré par CCT uniquement en variante B.

Fiche DPA — OpenRouter

Champ	Valeur
Fournisseur	OpenRouter, Inc. (États-Unis)
Rôle	Sous-traitant (art. 28 RGPD) — passerelle d'inférence IA
Service utilisé	API OpenRouter (AI_PROVIDER=openrouter) : génération des documents closure (modèles Claude Haiku/Sonnet) + OCR vision des pièces de préinscription
Données transmises	Prompts closure : noms des stagiaires , contexte des sessions (produit, dates, formateur) ; OCR vision : images CNI/RIB/CFP uploadées au formulaire de préinscription (pilier #4)
Localisation	États-Unis (transfert hors UE) — l'inférence est routée vers les providers de modèles (Anthropic pour QualiOF, voir anthropic.md)
Document DPA public	⚠ DPA mutuellement signé = tier ENTERPRISE UNIQUEMENT — non disponible en self-serve (statut actuel de Start Academy). Vérifié auprès du support OpenRouter, 2026-07. Référence support : https://openrouter.zendesk.com/hc/en-us/articles/47828437697051 · Politique de confidentialité : https://openrouter.ai/privacy (vérifiée 200 le 2026-07-06)
Garanties de transfert hors UE	Pas de clauses contractuelles types signées bilatéralement en self-serve. Garanties effectives (techniques) ci-dessous.
Date de vérification	2026-07-06 (URLs re-vérifiées HTTP 200)

Garanties effectives (réelles, vérifiables)

- Politique par défaut de non-rétention des prompts : OpenRouter ne conserve pas le contenu des prompts/réponses par défaut — seules des **métadonnées** (tokens, modèle, latence) sont journalisées pour la facturation.
- Réglages compte à vérifier et capturer (action au moment de la bascule) :
 - Logging OFF dans les settings du compte (désactiver toute rétention optionnelle de prompts) ;
 - Option ZDR (Zero Data Retention) sur les endpoints : <https://openrouter.ai/docs/guides/features/zdr> (vérifiée 200 le 2026-07-06) — restreint le routage aux endpoints providers garantissant zéro rétention.
- Trust Portal OpenRouter consultable pour les certifications de sécurité.

Réponse préparée pour un auditeur qui demanderait le DPA signé

« Start Academy utilise OpenRouter en offre self-serve, pour laquelle le fournisseur ne propose pas de DPA mutuellement signé (réservé au tier entreprise — vérifié auprès du support, 2026-07). Les garanties effectives en place sont : politique contractuelle par défaut de non-rétention des prompts (métadonnées seules), réglage logging OFF sur le compte, et enforcement ZDR (Zero Data Retention) sur les endpoints d'inférence. Ces réglages sont capturés en preuve. Si un DPA signé devenait une exigence formelle, la migration vers le tier entreprise OpenRouter est la voie identifiée. »

Points ouverts / limites

- ⚠ **Pas de DPA signé** (self-serve) — limite assumée, à valider par le responsable de traitement (gate D-13, cf. registre § Limites connues).
- ⚠ Réglages ZDR/logging OFF à **vérifier et capturer** (screenshot) avant la bascule prod — action à intégrer au runbook.
- Mitigation possible si exigence renforcée un jour : ZDR enforcement systématique ; tier entreprise (DPA signé).

Fiche DPA — OVH (SMTP)

Champ	Valeur
Fournisseur	OVH SAS (OVHcloud) — société française, siège à Roubaix
Rôle	Sous-traitant (art. 28 RGPD) — transport des emails
Service utilisé	SMTP <code>ssl0.ovh.net:465</code> (connexion SSL/TLS) — envoi des emails transactionnels de QualiOF
Données transmises	Contenu des emails apprenants et payeurs : convocations, notifications documentaires, relances de factures (noms, sessions, montants, pièces jointes le cas échéant)
Localisation	France / Union européenne — OVHcloud héberge ses services email sur ses infrastructures européennes
Document DPA public	Le DPA (accord de traitement des données) est intégré aux conditions contractuelles OVHcloud ; engagements RGPD publiés : https://www.ovhcloud.com/fr/personal-data-protection/ (vérifiée 200 le 2026-07-06)
Garanties de transfert hors UE	Non applicable en principe (société française, données UE). ⚠ La localisation précise du service email mutualisé n'est pas garantie contractuellement ligne à ligne — à vérifier si un auditeur le demande.
Date de vérification	2026-07-06 (URL re-vérifiée HTTP 200)

Mesures techniques côté QualiOF

- Connexion SMTP chiffrée (SSL, port 465) ; `SMTP_PASS` en variable d'environnement chiffrée (Vercel + Railway).
- `MAIL_DRY_RUN=true` tant que la bascule production n'est pas validée : aucun email réel ne part.
- Aucun envoi de masse vers les apprenants sans action explicite** (opt-in par case à cocher, `notifyLearners` défaut `false`) — exigence du responsable de traitement.
- Crons de relance préinscriptions/OPCO volontairement débranchés à la bascule.

Points ouverts / limites

- La bascule `MAIL_DRY_RUN=false` (plan 22-06+) est conditionnée au rapport préalable des envois en attente + validation Laurent (D-06).

Fiche DPA — Railway

Champ	Valeur
Fournisseur	Railway Corp.
Rôle	Sous-traitant (art. 28 RGPD) — exécution des workers de fond
Service utilisé	3 services (plan Pro) : worker QualiOF (closure/veille/relances/OCR sous pm2) + gotenberg-proxy + weasyprint (moteurs HTML→PDF)
Données transmises	Génération des documents Qualiopi : contenus HTML des documents (noms stagiaires, données sessions) rendus en PDF ; logs des workers (audités D-17 au plan 22-02 : les logs référencent des IDs, jamais nom/CNI/RIB en clair) ; emails de relances factures via SMTP (transport OVH, voir ovh-smtp.md)
Localisation	europe-west4 (Pays-Bas, UE) — fixé en config-as-code, cf. <code>17-REGIONS.md</code>
Document DPA public	https://railway.com/legal/dpa (vérifiée 200 le 2026-07-06) + Trust Center Railway. Subprocessors déclarés : GCP (infrastructure), Stripe (facturation), Cloudflare (réseau) .
Garanties de transfert hors UE	Workloads en région UE (europe-west4 sur GCP). DPA public couvrant la chaîne de subprocessors.
Date de vérification	2026-07-06 (URL re-vérifiée HTTP 200)

Mesures techniques côté QualiOF

- Moteurs PDF exposés protégés par Bearer token (`DOC_ENGINE_TOKEN`) ; service worker privé (réseau interne Railway).
- 5 secrets chiffrés en variables de service (`SUPABASE_SERVICE_ROLE_KEY`, `OPENROUTER_API_KEY`, `DOC_ENGINE_TOKEN`, `AUTH_SECRET`, `SMTP_PASS`).
- Audit logs PII réalisé (plan 22-02) sur les `console.*` du worker et des générateurs.

Points ouverts / limites

- Les logs Railway (stdout des services) sont conservés par la plateforme selon sa politique de rétention — l'audit D-17 garantit qu'ils ne contiennent pas de PII brut. ⚠ Durée de rétention des logs côté Railway non vérifiée précisément — à vérifier si un auditeur le demande.

Fiche DPA — Supabase

Champ	Valeur
Fournisseur	Supabase, Inc.
Rôle	Sous-traitant (art. 28 RGPD) — hébergement des données
Service utilisé	Postgres managé (projet <code>gntlqyscahbgjrmsbzil</code> , plan payant) + Storage (buckets <code>qualiof-docs</code> , <code>preinscriptions</code>)
Données transmises	TOUTE la base de données : PII apprenants/formateurs/contacts (<code>Person</code>), données sensibles isolées (<code>SensitiveData</code> : n° SS, référence pièce d'identité), préinscriptions, facturation, comptes utilisateurs — + Storage : pièces d'identité (CNI), RIB, attestations CFP, PDF Qualiopi générés
Localisation	eu-west-1 (Irlande, UE) — région DÉFINITIVE (immuable côté Supabase ; dérogation « données en France » actée par Laurent, cf. <code>17-REGIONS.md</code> amendement D-05). Backups quotidiens (rétention 7 jours) stockés dans la même région que le projet (UE ✓).
Document DPA public	https://supabase.com/legal/dpa (vérifiée 200 le 2026-07-06) — acceptation via le dashboard de l'organisation (Organization Settings → Legal Documents / Documents). ⚠ Action à faire si pas déjà fait : accepter le DPA dans le dashboard org et conserver la preuve (capture/horodatage).
Garanties de transfert hors UE	Données du projet en région UE (eu-west-1). Le DPA Supabase couvre les subprocessors (infrastructure AWS pour la région du projet).
Date de vérification	2026-07-06 (URL re-vérifiée HTTP 200)

Mesures techniques côté QualiOF

- Bucket Storage **privé** : accès exclusivement par signed URLs à TTL de quelques minutes ; upload direct-to-storage.
- Table `SensitiveData` séparée (1:1 `Person`, cascade delete).
- Connexion via pooler (:6543) chiffrée ; `SUPABASE_SERVICE_ROLE_KEY` stockée en variable d'environnement chiffrée (jamais dans le repo).

Points ouverts / limites

- ⚠ **Statut d'acceptation du DPA dashboard à vérifier/capturer** avant la bascule (action runbook).
- ⚠ **Backups non off-site** : rétention 7 jours dans la même région que le projet — pas de copie hors vendor (backlog `pg_dump` externe, décision D-12). Limite assumée, à valider par le responsable de traitement.

Fiche DPA — Vercel

Champ	Valeur
Fournisseur	Vercel, Inc.
Rôle	Sous-traitant (art. 28 RGPD) — hébergement applicatif
Service utilisé	Hébergement de l'application Next.js QualiOF (projet <code>qualiof</code> , plan Pro) : rendu des pages, server actions, API routes
Données transmises	Runtime applicatif : cookies de session (authentification Lucia), données du formulaire public de préinscription (identité candidat — les pièces CNI/RIB partent en direct-to-storage vers Supabase, elles ne transitent PAS par Vercel), payloads des requêtes des utilisateurs internes
Localisation	Fonctions serverless en cdg1 (Paris, France) — configuré <code>vercel.json</code> <code>"regions": ["cdg1"]</code> + Project Settings. ⚠ Le réseau edge Vercel est GLOBAL : les réponses HTTP transitent par le point de présence (POP) le plus proche du visiteur, potentiellement hors UE — le traitement/stockage applicatif reste en <code>cdg1</code> .
Document DPA public	https://vercel.com/legal/dpa (vérifiée 200 le 2026-07-06) — DPA incorporé aux conditions du service.
Garanties de transfert hors UE	DPA public Vercel (clauses de transfert incluses). Le point edge global est documenté ci-dessus en transparence.
Date de vérification	2026-07-06 (URL re-vérifiée HTTP 200)

Mesures techniques côté QualiOF

- Cookies de session `httpOnly`, `secure` en production, `sameSite=lax` ; invalidation en base au logout.
- Variables d'environnement sensibles chiffrées (sensitive) sur le projet Vercel.
- WAF : rate-limiting sur `/preinscription` (30 req/60 s par IP).
- `MAIL_DRY_RUN=true` et filigrane STAGING tant que la bascule prod n'est pas validée.

Points ouverts / limites

- ⚠ Transit edge global (POP hors UE possibles pour la couche réseau) — inhérent au CDN Vercel ; à noter dans le registre, pas de mitigation applicative simple. ⚠ À VALIDER PAR LE RESPONSABLE DE TRAITEMENT (acceptation).